

LECTURE REPORT

CS50's Introduction to Cybersecurity

Lecture 4: Preserving Privacy

Instructor David J. Malan	Institution Harvard University	Module Week 4 of 4	Topic Focus Privacy Preservation
------------------------------	-----------------------------------	-----------------------	-------------------------------------

1. Overview

This final lecture of CS50's Introduction to Cybersecurity shifts focus from attack and defense techniques to the privacy dimension of security. The central question is: what information are we sharing — often unknowingly — as we use the web, and what practical tools exist to limit that exposure? The lecture examines the full lifecycle of user tracking, from HTTP headers and cookies to DNS queries and network-level identifiers, and evaluates the strengths and limitations of privacy-enhancing technologies.

2. Web Browsing History

A browser's local history is a record of websites visited, stored on the user's own device. While clearing this history removes local evidence of browsing, it provides only a superficial layer of privacy protection for two key reasons:

- Clearing browser history typically logs the user out of all active sessions, creating a usability cost.
- Web servers independently maintain server-side logs of every request they receive, regardless of what the client does locally.

A typical web server log entry captures the following fields:

```
log_format combined '$remote_addr - $remote_user [$time_local] '
                    '$request' $status $body_bytes_sent '
                    '$http_referer' '$http_user_agent';
```

This log records the visitor's IP address, the timestamp of the request, the specific resource requested, the HTTP status code returned, the referring URL, and the browser's user-agent string. None of this data is erased when a user clears their local history. Server-side logging is therefore a persistent and authoritative record of user activity that is entirely outside the user's control.

3. HTTP Headers & the Referer Header

Every HTTP request includes a set of headers — metadata key-value pairs that convey contextual information to the server. One of the most privacy-sensitive is the Referer header, which browsers send automatically to indicate which page or URL led the user to the current request.

Consider a page with the following link:

```
<a href="https://example.com">cats</a>
```

If a user arrives at that link from a Google search for 'cats', the browser sends:

```
Referer: https://www.google.com/search?q=cats
```

This reveals the user's search query to the destination server — information the user did not explicitly choose to share. The following approaches exist to control how much referrer information is disclosed:

Referrer Policy Value	Information Shared	Use Case
(default / no policy)	Full URL including path and query string	Standard web navigation with no privacy restriction
origin	Only the origin (scheme + host), e.g. https://www.google.com/	Reduces query exposure while preserving referral source
none / no-referrer	No Referer header sent at all	Maximum referrer privacy; destination sees no origin

These policies are set by website owners via HTML meta tags:

```
<meta name="referrer" content="origin">
<meta name="referrer" content="none">
```

It is important to note that these controls are applied by the referring website's author, not by the end user. Users do not have direct control over what the sites they visit disclose about them.

4. Browser Fingerprinting

Fingerprinting is a tracking technique that identifies users by aggregating a set of attributes about their browser and device — without relying on cookies or any persistent identifier that the user could delete. Even when a user takes steps to limit data sharing, the combination of many small pieces of disclosed information can create a highly unique profile.

The User-Agent request header is one such data point, revealing the browser name and version, the underlying rendering engine, the operating system and version, and whether the device is mobile:

```
Mozilla/5.0 (Linux; {Android Version}; {Build Tag etc.})
AppleWebKit/{WebKit Rev} (KHTML, like Gecko)
Chrome/{Chrome Rev} Mobile Safari/{WebKit Rev}
```

Beyond the User-Agent, the following attributes are commonly collected and combined to build a fingerprint:

- IP address — logged by every server the user contacts.
- Screen resolution — width, height, and color depth of the display.
- Installed browser extensions — the set of active extensions alters page rendering in detectable ways.
- Installed fonts — the list of fonts available on the system varies significantly by OS and configuration.
- Time zone and language settings — locale preferences sent with requests.
- Hardware concurrency and device memory — exposed via browser APIs.

The critical insight is that no single attribute uniquely identifies a user, but their combination — the fingerprint — can be statistically unique across the global population of internet users. Unlike cookies, fingerprints cannot be cleared or blocked by the user in a straightforward way, making them a particularly persistent tracking mechanism.

5. Session Cookies

A session cookie is a small piece of data that a server places on a client's browser to maintain state across HTTP requests, which are otherwise stateless. Because HTTP does not natively remember who a user is from one request to the next, session cookies are the standard mechanism by which servers recognize a returning user within a single browsing session.

The server sets a session cookie in its HTTP response:

```
HTTP/3 200
Set-Cookie: session=1234abcd
```

On all subsequent requests to the same server, the browser automatically attaches this cookie, allowing the server to identify the user without requiring them to log in again for each page load. Key characteristics:

- Session values are unique per user — no two users share the same session identifier.
- Session cookies typically expire after a server-defined period of inactivity, or when the browser is closed (depending on server configuration).
- If a session cookie is stolen (e.g., via XSS), an attacker can impersonate the victim — a threat called session hijacking.

6. Tracking Cookies

While session cookies serve a functional purpose (maintaining login state), tracking cookies are designed specifically to monitor user behavior over time. They are typically set by analytics platforms or advertising networks and persist across many browsing sessions.

A representative example is the Google Analytics cookie:

```
Set-Cookie: _ga=GA1.2.0123456789.0; max-age=63072000
```

The max-age value of 63,072,000 seconds corresponds to two years. During that entire period, the cookie is automatically sent to every site that loads Google Analytics code, allowing Google to track the user's visits across all such properties and build a behavioral profile over time.

7. Tracking Parameters

Tracking parameters are identifiers embedded directly in URLs, visible in the browser's address bar. Unlike cookies, which operate invisibly in the background, tracking parameters are part of the URL string itself and are therefore transmitted in every log entry and referrer header.

Example of a URL with granular user tracking:

```
https://example.com/ad_engagement?click_id=YmVhODI1MmZmNGU4&campaign_id=23
```

In this URL, `click_id=YmVhODI1MmZmNGU4` identifies the specific individual user who clicked the link, while `campaign_id=23` identifies the marketing campaign. If the `click_id` is stripped, tracking is reduced to campaign-level analytics:

```
https://example.com/ad_engagement?campaign_id=23
```

Modern browsers are increasingly implementing automatic stripping of known tracking parameters before navigation, reducing the granularity of user-level identification without breaking the destination page. This represents a privacy improvement at the browser layer that does not require any action from the user.

8. Third-Party Cookies

A third-party cookie is set not by the website the user is directly visiting (the first party), but by a different domain whose resources are embedded in that page — such as an advertisement, an analytics script, or a social media widget. Third-party cookies enable cross-site tracking: a single company can observe a user's behavior across every website that embeds their resources.

Step 1 — User visits `harvard.edu`, which embeds an ad served by `example.com`:

```
GET /ad.gif HTTP/3
Host: example.com
Referer: https://harvard.edu/
```

Step 2 — `example.com` responds and sets a persistent cookie:

```
HTTP/3 200
Set-Cookie: id=1234abcd; max-age=31536000
```

The max-age of 31,536,000 seconds is one year. The cookie is now stored in the user's browser associated with the domain example.com.

Step 3 — User later visits yale.edu, which also embeds example.com's ad:

```
GET /ad.gif HTTP/3
Cookie: id=1234abcd
Host: example.com
Referer: https://yale.edu/
```

example.com now knows, with certainty, that the same user (identified by id=1234abcd) visited both harvard.edu and yale.edu. By extending this mechanism across thousands of websites, advertising networks can construct detailed profiles of users' interests, demographics, and behaviors — which are then monetized through targeted advertising or sold to data brokers.

9. Private Browsing

Private browsing mode (also known as Incognito mode) is a browser feature that provides a degree of local isolation for a browsing session. It is commonly misunderstood as providing comprehensive anonymity.

What private browsing does:

- Opens a fresh session with no pre-existing cookies from the regular browser profile — previously set tracking cookies are not present.
- Does not write browsing history, form data, or new cookies to disk after the session ends.

What private browsing does NOT do:

- New cookies can still be set and sent within the private session — tracking is still possible for the duration of that session.
- Servers still receive and log the user's IP address, User-Agent, and all other request metadata.
- The user's ISP and network administrators can still observe which IP addresses and domains are being contacted.
- Private browsing provides no protection against fingerprinting.

Private browsing is most useful for preventing local access to browsing history (e.g., on a shared computer) rather than for protecting against server-side or network-level tracking.

10. Supercookies

A supercookie is a tracking identifier injected directly into HTTP headers by an Internet Service Provider (ISP) at the network level, before the traffic reaches the destination server. Unlike browser-

set cookies, supercookies are completely outside the user's control — they cannot be cleared from the browser, and the user may have no awareness of their existence.

- The ISP inserts a unique identifier (sometimes called a UIDH — Unique Identifier Header) into every unencrypted HTTP request the user makes.
- Destination websites and advertising partners can read this identifier and use it to track users persistently.
- Using HTTPS encrypts the HTTP headers, preventing ISP injection of supercookies into encrypted traffic.
- Some ISPs offer an opt-out mechanism for supercookie injection, though this is not universal.

11. DNS & Encrypted DNS

The Domain Name System (DNS) is the internet's phonebook: it translates human-readable domain names such as harvard.edu into the numeric IP addresses that computers use to route traffic. Every website visit begins with a DNS query, which means DNS traffic is a comprehensive record of every domain a user attempts to contact.

Privacy concern:

- By default, DNS queries are transmitted in plaintext over UDP port 53 — completely unencrypted and unauthenticated.
- Any party on the network path — the ISP, network administrators, or a malicious intermediary — can observe every DNS query the user makes.
- The DNS resolver itself (typically operated by the ISP) has a complete log of the user's DNS queries.

Encrypted DNS solutions address this by wrapping DNS queries in an encrypted transport layer:

Protocol	Full Name	Transport	Key Privacy Benefit
DoH	DNS over HTTPS	HTTPS (TCP port 443)	Queries are indistinguishable from ordinary web traffic; hides DNS from network observers.
DoT	DNS over TLS	TLS (TCP port 853)	Encrypts DNS queries in a dedicated TLS tunnel; clearly identifiable as DNS traffic but content is encrypted.

It is important to note that encrypted DNS protects the confidentiality of the query from network observers, but the DNS resolver that processes the query still sees every domain name resolved. Choosing a trusted DNS resolver (or operating one's own) remains important for full DNS privacy.

12. Virtual Private Networks (VPNs)

A Virtual Private Network (VPN) creates an encrypted tunnel between the user's device and a trusted intermediary server. All of the user's internet traffic is routed through this tunnel, so it reaches the internet as if it originated from the VPN server's IP address rather than the user's own.

How a VPN works:

- The user's device (A) establishes an encrypted connection to a VPN server (B).
- All outbound traffic from A is encrypted and sent to B inside the tunnel.
- B decrypts the traffic and forwards it to the destination on the internet.
- The destination sees B's IP address as the source — not A's.

Privacy benefits:

- ISPs and local network observers see only encrypted traffic to the VPN server — they cannot observe which sites the user visits.
- The user's real IP address is hidden from the destination servers and any intermediate parties.

Important limitations:

- The VPN provider itself sees all of the user's traffic — trust shifts from the ISP to the VPN operator.
- VPNs provide no protection if the user's device is already compromised by malware — malicious software can exfiltrate data before it enters the VPN tunnel.
- VPNs do not prevent fingerprinting, tracking cookies, or tracking parameters.

13. Tor (The Onion Router)

Tor is an anonymity network and associated software that routes internet traffic through a series of volunteer-operated relay nodes, applying a layer of encryption at each hop. The name derives from its layered encryption model — like the layers of an onion.

How Tor provides anonymity:

- Traffic is encrypted in multiple layers and routed through at least three nodes: an entry (guard) node, a middle relay, and an exit node.
- Each node decrypts only one layer of encryption — revealing only the next hop, not the full path.
- The entry node knows the user's IP address but not the destination.
- The exit node knows the destination but not the user's IP address.
- No single node possesses both the source and destination simultaneously.
- By design, Tor does not persistently store routing information, further limiting traceability.

Limitations and caveats:

- Tor significantly raises the bar for identification but does not guarantee absolute anonymity.
- If a user is the only person on a local network (e.g., a workplace or school) using Tor at a given time, correlation attacks using traffic timing analysis may allow an adversary to identify the user through other means.
- Exit node traffic is unencrypted between the exit node and the destination (unless the destination uses HTTPS); a malicious exit node can observe plaintext traffic.
- No technology provides absolute protection. Operational security (OPSEC) practices matter alongside technical tools.

14. Operating System Permissions

Modern operating systems — including iOS, Android, macOS, and Windows — present users with explicit permission prompts before applications can access sensitive device capabilities. This mechanism gives users a degree of control over what data applications can collect.

Location-based services are among the most privacy-sensitive permissions:

- Mapping applications such as Apple Maps and Google Maps require location access to provide navigation and real-time guidance.
- Granting location permission means the service operator has a continuous record of the user's geographic location during use.
- Users should evaluate whether each application genuinely requires the permissions it requests, and configure permissions to the minimum necessary level (e.g., 'While Using the App' rather than 'Always').

The principle of least privilege applies to permissions: an application should only be granted access to the resources it strictly needs to perform its stated function. Granting unnecessary permissions expands the attack surface and the scope of potential data exposure.

15. Comparative Summary of Privacy Technologies

The following table summarizes the privacy tools discussed in this lecture, the threats each addresses, and their key limitations:

Technology	Primary Threat Addressed	Key Limitation
Referrer Policy (origin / none)	Leaking search queries and browsing context via Referer header	Controlled by website authors, not end users
Private Browsing / Incognito	Local browser history on shared devices	Does not hide from servers, ISPs, or fingerprinting
Tracking Parameter Stripping	User-level URL tracking identifiers	Browser-dependent; campaign-level tracking still possible

Blocking Third-Party Cookies	Cross-site behavioral tracking by ad networks	Fingerprinting and other methods can substitute
DNS over HTTPS / TLS (DoH/DoT)	Plaintext DNS queries visible to ISP and network	DNS resolver itself still sees all queries
VPN	IP address exposure; ISP traffic observation	VPN provider sees all traffic; no malware protection
Tor	IP address linkability across sites and sessions	Slow; vulnerable to traffic correlation at network level
OS Permissions	Unauthorized app access to location, camera, mic	Users must actively manage; many grant broad permissions by default

16. Course Summary

This lecture concludes CS50's Introduction to Cybersecurity. Across the four weeks, the course covered the following domains:

Week	Topic	Core Concepts
0	Securing Accounts	Passwords, password managers, multi-factor authentication, phishing awareness
1	Securing Data	Encryption (symmetric & asymmetric), hashing, digital signatures, HTTPS/TLS
2	Securing Systems	Firewalls, malware, ransomware, updates and patching, network security
3	Securing Software	XSS, SQL injection, CSRF, ACE/buffer overflow, prepared statements, app stores
4	Preserving Privacy	Cookies, fingerprinting, DNS, VPNs, Tor, tracking parameters, OS permissions

The overarching insight of the course is that cybersecurity is not a binary state — no system is perfectly secure and no technology guarantees absolute privacy. The goal is to raise the bar for adversaries: to make attacks more costly, more detectable, and less rewarding, while maintaining usability for legitimate users. Awareness is the first and most fundamental defense.

End of Lecture 4 Notes — End of CS50 Cybersecurity